

CISSP Printable Practice Exam 23 - Domain 7 - Security Operations

Practice Exam 03 - Domain 7

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP3-117)

Scenario: A regional lender receives a regulator's notice requesting records related to suspected unauthorized changes in customer loan files. The requested period and systems are clearly defined, and some relevant audit records will reach the end of their retention period within a week.

Which action should the security manager prioritize?

- A. Preserve the defined records, document collection methods, and coordinate production through legal and compliance teams
- B. Expand the inquiry to every employee and system before preserving the records named in the notice
- C. Provide investigators with unrestricted live access to all production systems
- D. Shorten the retention period so only the most recent activity remains available

Question 2 (CISSP3-118)

Scenario: An incident responder must collect evidence from a compromised cloud-hosted virtual server. Direct access to the underlying physical storage is unavailable, but the service supports point-in-time snapshots, audit exports, and cryptographic hashes.

What is the BEST evidence-acquisition approach?

- A. Copy selected files through the compromised server and omit provider records
- B. Ask the system owner to email screenshots of the files that appear suspicious
- C. Use supported snapshots and audit exports, record provenance and timestamps, and verify acquired data with hashes
- D. Restart the server repeatedly until a physical disk image becomes available

Question 3 (CISSP3-119)

Scenario: A global engineering firm stores all security logs for the same short period. Investigators recently discovered that authentication records needed to examine a slow-moving intrusion had already been deleted, while large volumes of low-value diagnostic data consumed most storage capacity.

How should the firm redesign its security log retention policy?

- A. Retain every event category indefinitely in its original high-volume format
- B. Keep only alerts that analysts classified as incidents on the day they occurred
- C. Let each administrator delete records whenever local storage becomes constrained
- D. Define retention tiers by legal need, investigative value, data source, and business risk

Question 4 (CISSP3-120)

Scenario: A pharmaceutical laboratory cannot apply one hardening setting to several instruments because the setting disrupts validated research software. Management permits a temporary deviation from the server baseline while a compatible solution is developed.

Which THREE controls are MOST important for managing the exception? Select 3 of the 5 options below.

- A. Remove the instruments from configuration monitoring so the deviation produces no alerts

- B. Document the business justification, affected assets, risk, and approving authority
- C. Treat the exception as permanent because the software is currently validated
- D. Apply appropriate compensating controls and monitor their effectiveness
- E. Set an expiration or review date and track progress toward remediation

Question 5 (CISSP3-121)

Scenario: A consumer electronics company is investigating suspected theft of unreleased product designs. Many employees ask to join the incident collaboration channel because rumors are spreading, but only a small cross-functional team has assigned response duties.

How should access to incident details be managed?

- A. Grant access to all employees so the investigation appears transparent
- B. Provide role-specific information only to authorized participants with a defined operational need
- C. Restrict every detail to the lead investigator, including tasks required by technical responders
- D. Publish raw evidence internally after removing the incident title

Question 6 (CISSP3-122)

Scenario: A municipal services provider maintains a break-glass administrator account for use when the normal identity platform is unavailable. The password is currently known to several technicians and the account is excluded from monitoring.

Which redesign would BEST protect the emergency capability?

- A. Keep the shared password unchanged so technicians can recall it during an outage
- B. Use the emergency account for routine maintenance to confirm that it still works
- C. Disable logging to prevent emergency activity from filling the monitoring system
- D. Secure the credential under controlled release, alert on use, record activity, and rotate it after each activation

Question 7 (CISSP3-123)

Scenario: After acquiring a smaller company, a publishing group discovers active servers, removable media, and network appliances that do not appear in either organization's asset records. Several systems have no identified business owner.

What should operations management do FIRST?

- A. Inventory and reconcile the assets, assign accountable owners, and determine authorized disposition or continued use
- B. Connect every unidentified device to the production network to discover its purpose
- C. Discard all unrecorded equipment before checking for business data or retention obligations
- D. Allow local teams to retain devices indefinitely without central records

Question 8 (CISSP3-124)

Scenario: A hotel chain has contained malware on a reservation server. Analysts found persistence mechanisms, stolen service credentials, and communication with several internal hosts. Management wants to return the server to production quickly.

Which THREE actions should be completed before or as part of controlled recovery? Select 3 of the 5 options below.

- A. Remove persistence or rebuild from a trusted source and verify the result
- B. Reconnect the server before investigating potentially affected internal hosts
- C. Rotate compromised credentials and review dependent services

- D. Preserve the pre-recovery logs and evidence required by the response process
- E. Restore the last available backup without determining whether it contains the compromise

Question 9 (CISSP3-125)

Scenario: A legal services firm receives document attachments that evade signature-based anti-malware checks. Analysts need to observe file behavior before allowing the attachments onto user workstations.

Which control BEST meets the requirement?

- A. Open each attachment on an analyst's normal workstation with local administrator rights
- B. Add every attachment sender to a permanent network blocklist
- C. Detonate the attachments in an isolated sandbox and evaluate their behavior and indicators
- D. Disable attachment inspection so documents arrive without processing delays

Question 10 (CISSP3-126)

Scenario: A media streaming company receives credible indicators for command-and-control addresses used in an active campaign. Some addresses are hosted on shared infrastructure that also serves legitimate customers.

What is the BEST operational response?

- A. Permanently block every address associated with the hosting provider
- B. Validate context, apply scoped time-bound blocks where justified, monitor effects, and review the indicators
- C. Ignore all network indicators because shared hosting can create false positives
- D. Replace existing firewall policy with the external indicator list without approval

Question 11 (CISSP3-127)

Scenario: A diagnostic imaging system cannot accept a security patch until a compatibility review is completed. The vulnerability is relevant to the system, but network segmentation and strict administrative access can reduce exposure during the review period.

How should the security manager handle the delayed patch?

- A. Close the vulnerability record because compensating controls are available
- B. Install the patch immediately without clinical or technical review
- C. Leave the system unchanged and omit the issue from risk reporting
- D. Approve a time-limited exception with compensating controls, ownership, monitoring, and a remediation date

Question 12 (CISSP3-128)

Scenario: An online education provider's intrusion prevention system repeatedly blocks legitimate enrollment traffic after a new signature update. The same signature may still detect a meaningful attack pattern elsewhere in the environment.

Which response BEST balances protection and availability?

- A. Confirm the false-positive pattern, narrow or stage the rule for affected traffic, and monitor the revised control
- B. Disable the entire intrusion prevention platform across the enterprise
- C. Accept the enrollment failures because prevention rules should not be adjusted
- D. Exclude all enrollment systems from security monitoring

Question 13 (CISSP3-129)

Scenario: A wholesale distributor must restore its inventory system within 12 hours after losing the primary facility. The organization can tolerate several hours of configuration and data restoration but cannot wait for new hardware to be purchased and delivered. A continuously synchronized duplicate environment exceeds the approved budget.

Which recovery site is the BEST fit?

- A. A cold site containing office space and utilities but no installed computing equipment
- B. A warm site with installed infrastructure that requires configuration and data restoration
- C. A mirrored site with continuously synchronized processing and immediate failover
- D. A vacant warehouse selected only after the disruption occurs

Question 14 (CISSP3-130)

Scenario: A design firm's project repository has been silently corrupted for several days. Recent backups completed successfully, but completion status alone does not show whether the copied data was already damaged.

What should the recovery team do before restoring production?

- A. Restore the newest backup because its job completed without an error
- B. Combine files from several backups without preserving their original versions
- C. Determine the corruption window, validate candidate backups, and restore the newest verified clean point
- D. Delete older backups so the team cannot select an outdated copy

Question 15 (CISSP3-131)

Scenario: After a regional outage, a nonprofit's alternate site has limited network capacity. Voice coordination, identity services, database replication, and large noncritical software downloads compete for the same link, degrading critical recovery activity.

Which measure would MOST directly improve recovery performance?

- A. Increase the retention period for network device configuration logs
- B. Route every traffic class with equal priority during the outage
- C. Suspend monitoring until all systems have returned to the primary site
- D. Apply tested quality-of-service priorities aligned with critical recovery functions

Question 16 (CISSP3-132)

Scenario: A credit union has revised its disaster recovery plan and wants process owners to review their responsibilities together, trace the response to a presented outage, and identify missing dependencies without activating recovery systems.

Which THREE activities belong in this walkthrough? Select 3 of the 5 options below.

- A. Participants discuss the sequence of actions and handoffs for the presented event
- B. Production services are shut down and fully transferred to the alternate site
- C. Teams compare contact, resource, vendor, and dependency information against current conditions
- D. Facilitators record gaps, owners, and follow-up actions identified during discussion
- E. Recovered systems process live member transactions throughout the exercise

Question 17 (CISSP3-133)

Scenario: A remote telecommunications facility has a perimeter fence and locked equipment

building. After several nighttime intrusion attempts, responders report that alarms do not show where entry was attempted and poor lighting prevents camera operators from assessing events.

Which combination of safeguards would most directly enable responders to locate and assess a perimeter breach?

- A. Raise the interior office partition walls without changing perimeter monitoring
- B. Replace the equipment locks while leaving alarms and assessment capability unchanged
- C. Add zoned intrusion sensors, suitable lighting, camera coverage, and documented response procedures
- D. Post the alarm schedule publicly so nearby residents can investigate events

Question 18 (CISSP3-134)

Scenario: Authorities report an airborne chemical release near a call center and instruct nearby facilities to shelter in place. The building has designated interior refuge areas and a procedure for shutting down outside-air intake.

What should the site emergency coordinator do FIRST?

- A. Activate the shelter-in-place procedure, account for occupants, and follow official emergency instructions
- B. Send all occupants outside to the parking area for a standard fire-drill muster
- C. Keep exterior doors open so employees arriving late can enter quickly
- D. Wait for visible symptoms before communicating with personnel

Question 19 (CISSP3-135)

Scenario: Employees at a distribution company report that they do not know how to raise concerns about threats or escalating aggressive behavior. Managers currently handle reports informally, and workers fear that their identities will be disclosed unnecessarily.

What program would most effectively improve early reporting and safe escalation?

- A. Require employees to confront the person directly before making a report
- B. Provide training, confidential reporting paths, defined escalation, and coordinated safety response procedures
- C. Publish every report and reporter's identity to discourage unsupported concerns
- D. Treat aggressive behavior solely as an information technology issue

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP3-117) - Correct: A

The organization should promptly preserve the records within scope, document how they were collected, and coordinate a controlled response through legal and compliance functions.

Expanding the inquiry before securing expiring evidence risks loss and unnecessary intrusion. Unrestricted production access creates operational and confidentiality risks, while shortening retention could destroy relevant evidence.

Question 2 (CISSP3-118) - Correct: C

Provider-supported snapshots and audit exports can produce defensible cloud evidence when investigators document source, time, method, custody, and integrity hashes. Selective copying through a compromised host may alter metadata and omit context. Screenshots are incomplete, and repeated restarts can destroy volatile evidence without creating access to physical media.

Question 3 (CISSP3-119) - Correct: D

Risk-based retention tiers preserve valuable evidence for suitable periods while controlling storage and handling obligations. Indefinite retention of everything creates cost and data-governance burdens. Keeping only immediately confirmed incidents removes context needed for later discovery, and administrator-controlled deletion produces inconsistent and potentially indefensible retention.

Question 4 (CISSP3-120) - Correct: B, D, E

A controlled exception requires documented scope and authorization, compensating safeguards, and a defined review or expiration point with remediation tracking. Removing the assets from monitoring hides risk rather than managing it. Current operational need does not justify making the deviation permanent without periodic reassessment.

Question 5 (CISSP3-121) - Correct: B

Need-to-know permits authorized responders to receive the information required for their roles while limiting unnecessary exposure of sensitive evidence and allegations. Organization-wide access is excessive, but withholding task-critical information from responders impedes the investigation. Removing a title does not make raw evidence safe for broad distribution.

Question 6 (CISSP3-122) - Correct: D

Controlled release, immediate alerting, activity records, and post-use rotation preserve emergency availability while maintaining accountability. A widely known static password invites misuse. Routine use defeats the exceptional purpose of the account, and disabling logging removes the evidence needed to review powerful emergency actions.

Question 7 (CISSP3-123) - Correct: A

Reconciliation and ownership assignment establish accountability before the organization decides whether each asset should remain in service, be isolated, or be disposed of under applicable data-handling rules. Connecting unknown devices increases risk. Immediate disposal may destroy needed data, while undocumented local retention perpetuates the control gap.

Question 8 (CISSP3-124) - Correct: A, C, D

Trustworthy recovery requires removing persistence or rebuilding from a known-good source, replacing exposed credentials, and preserving evidence needed for investigation and reporting. Reconnection before checking related hosts can enable reinfection. A backup must

be validated against the compromise timeline rather than restored solely because it is the newest copy.

Question 9 (CISSP3-125) - Correct: C

An isolated sandbox allows analysts to observe process, file, and network behavior while reducing risk to production systems. Opening files on an ordinary privileged workstation creates exposure. Blocking every sender is overly broad and may not stop altered delivery methods, while disabling inspection removes a useful preventive and detective layer.

Question 10 (CISSP3-126) - Correct: B

Context-aware, scoped, time-limited blocking can reduce active risk while monitoring and review limit harm to legitimate services as indicators age. Provider-wide permanent blocking is disproportionate. Ignoring credible intelligence forfeits protection, and replacing policy wholesale bypasses governance and can cause extensive disruption.

Question 11 (CISSP3-127) - Correct: D

A time-limited, owned exception keeps the risk visible while compensating controls reduce exposure and compatibility work proceeds toward a defined remediation date. Closing or omitting the issue hides residual risk. Unreviewed installation may impair a safety-sensitive system and is not justified when controlled interim protection is feasible.

Question 12 (CISSP3-128) - Correct: A

Evidence-based tuning can preserve the signature's value while removing the specific condition that disrupts legitimate enrollment traffic; staged deployment and monitoring verify the result. Disabling the platform or excluding systems sacrifices broad protection. Accepting known business disruption without analysis fails to manage availability.

Question 13 (CISSP3-129) - Correct: B

A warm site provides installed infrastructure and can be activated through configuration and restoration within a moderate recovery window, without the cost of continuous mirroring. A cold site may take too long because equipment must be obtained or installed. A mirrored site exceeds the stated need and budget, while an unprepared warehouse is not a viable recovery site.

Question 14 (CISSP3-130) - Correct: C

The team should identify when corruption began and validate backup contents and integrity before selecting the newest clean recovery point. Successful job completion proves that data was copied, not that it was sound. Combining versions without control can spread corruption, and deleting older copies removes potentially valid restore options.

Question 15 (CISSP3-131) - Correct: D

Tested quality-of-service policies can prioritize voice, identity, and essential replication over noncritical downloads when capacity is constrained. Longer log retention does not allocate bandwidth. Equal treatment permits low-priority transfers to impair recovery, while suspending monitoring reduces visibility during a high-risk period.

Question 16 (CISSP3-132) - Correct: A, C, D

A walkthrough is a collaborative, discussion-based review of plan steps, responsibilities, handoffs, and dependencies, with findings captured for correction. It does not require production shutdown or live transaction processing; those activities introduce operational testing beyond the stated objective.

Question 17 (CISSP3-133) - Correct: C

Zoned sensors identify the event location, lighting and cameras support rapid assessment, and response procedures turn detection into action. Stronger interior partitions or locks may delay entry but do not correct poor alarm localization and assessment. Publicly assigning investigation to residents is unsafe and bypasses controlled response.

Question 18 (CISSP3-134) - Correct: A

The coordinator should follow the competent authority's shelter instruction, use the prepared refuge and ventilation procedures, and account for occupants. Moving people outdoors could expose them to the release. Open doors can admit contaminated air, and delaying action until symptoms appear sacrifices preventive life-safety measures.

Question 19 (CISSP3-135) - Correct: B

Training and confidential reporting, supported by defined escalation and coordinated response, help personnel raise concerns early without requiring unsafe confrontation or needless disclosure. Publishing identities can deter valid reports and increase risk. Workplace violence requires organizational safety coordination, not treatment as a purely technical matter.